Iteración 2 – Autenticación y Usuarios

1. Objetivo

Implementar el registro e inicio de sesión con roles (módulo **PA2**, RF-11), de modo que cada usuario vea únicamente lo que su rol permite.

2. Proceso de referencia (TO-BE PA2)

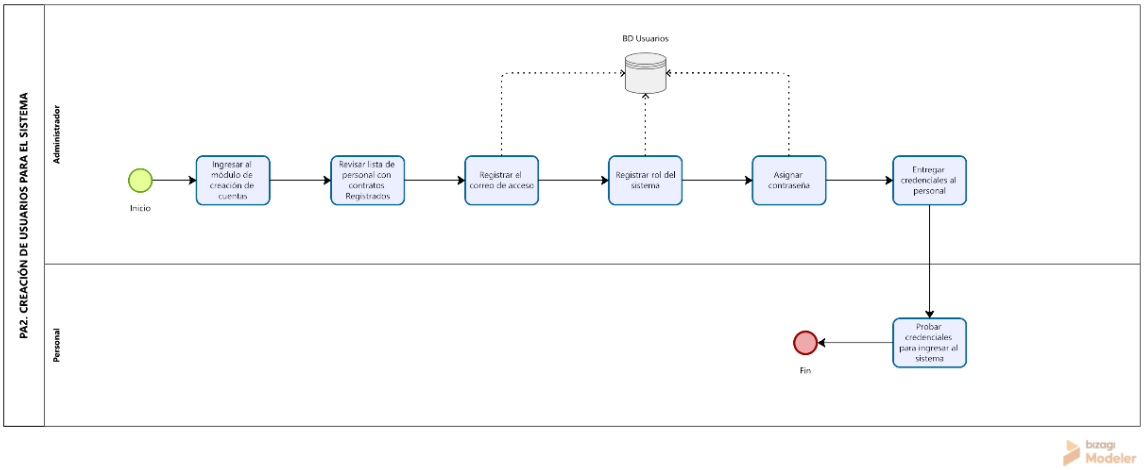


Figura 6. PA2 – Creación de usuarios.

3. Actividades

N.º	Actividad	Resultado
1	Implementar JWT en Laravel: `register`, `login`, `logout`, `me`.	Token emitido con expiración configurable.
2	Crear el middleware de roles (RBAC) `role:admin,conductor,...`	Rutas protegidas por rol; `403` si no corresponde.
3	Crear el formulario de Login en React y el cliente Axios con interceptor JWT.	Sesión persistente y renovación/cierre al expirar.
4	Dashboards diferenciados por rol (Administrador, Ciudadano, Conductor, Mantenimiento).	Redirección según el rol autenticado.
5	CRUD de usuarios internos para el Administrador (PA2): correo, rol y contraseña inicial.	Personal con acceso al sistema.
6	Rate limiting en login y registro de auditoría de inicios de sesión.	Bloqueo temporal tras intentos fallidos.

Matriz de permisos por rol (RBAC)

Funcionalidad	Ciudadano	Admin	Conductor	Mantenim.
Reportar incidencia / ver las propias	Sí	—	—	—
Ver y validar todas las incidencias	—	Sí	—	—
Generar, aprobar y asignar rutas	—	Sí	—	—
Ver rutas asignadas y subir evidencia	—	—	Sí	—
Registrar peso de disposición final	—	Ver / corregir con auditoría	Registrar (no editar)	—
Contratos, horarios, usuarios	—	Sí	—	—
Registrar mantenimiento de vehículos	—	Programar	—	Registrar resultado
Reportes e indicadores	—	Sí	—	—

4. Pruebas

ID	Caso de prueba	Entrada / condición	Resultado esperado	Resultado
IT2-01	Login exitoso	Email y contraseña correctos	Devuelve JWT y redirige al dashboard del rol.	Pendiente
IT2-02	Login fallido	Contraseña incorrecta	Mensaje genérico «Credenciales inválidas»; `401`.	Pendiente
IT2-03	Acceso denegado	Ciudadano llama a `POST /routes/generate`	`403 Forbidden`.	Pendiente
IT2-04	Ruta protegida sin sesión	Abrir `/admin` sin token	Redirige a login (`401` en la API).	Pendiente
IT2-05	Fuerza bruta	6 intentos fallidos seguidos	Bloqueo temporal por rate limiting (`429`).	Pendiente
IT2-06	Token expirado	JWT vencido	La API responde `401`; el frontend cierra sesión.	Pendiente
IT2-07	Contraseña almacenada	Revisar tabla `usuarios`	La contraseña es un hash Bcrypt, no texto plano.	Pendiente
IT2-08	Creación de usuario interno	Admin crea un conductor	Usuario creado con rol correcto y puede iniciar sesión.	Pendiente

5. Riesgos y soluciones previstas

Problema / riesgo	Solución / mitigación	Estado
CORS entre frontend (`:3000`) y backend (`:8000`).	Configurar `config/cors.php` con el origen del frontend.	Prevista
Almacenar el JWT en `localStorage` expone el token ante XSS.	Sanitizar entradas, cabeceras CSP y expiración corta del token.	Prevista
Reloj del servidor desfasado invalida tokens.	Sincronizar hora (NTP) en el servidor y contenedores.	Prevista